

CS 578: CYBER-SECURITY

PART I: APPLICATIONS

Sanghyun Hong

sanghyun.hong@oregonstate.edu



Oregon State
University



TRUE AI
Trustworthy and Responsible AI

ANNOUNCEMENT

- Checkpoint presentation 1
 - 10-12 min presentation + 2-3 min Q&A
 - Track 1 **MUST** cover:
 - A research problem your team chose
 - A review of the prior work relevant to your problem
 - The approach, and how is your approach different from the prior work?
 - Next steps (+ how each member will contribute to the work)

ANNOUNCEMENT – CONT'D

- Checkpoint presentation 1
 - 10-12 min presentation + 2-3 min Q&A
 - Track 2 **MUST** cover:
 - A chosen problem (distillation prevention or tracing)
 - The paper of your team's choice
 - This should be the bulk of your presentation
 - The threat model, the key idea, and the mechanism
 - The method and result(s) your team will reproduce
 - The specific claims/metrics from each paper
 - The datasets and models the team will use
 - How does it map onto the repository
 - Next steps (+ how each member will contribute to the work)

ANNOUNCEMENT – CONT'D

- No class on 10/7 (Wed): Checkpoint presentation 1 prep.
- No critique on 10/7 and 10/12
- In-class presentations
 - Check your date on the sheet
 - You must meet me once, ~0.5 weeks before your date

RECAP – WHERE WE ARE

- 09.28: The key was weak – Censys and Mining Your Ps and Qs
- 09.30: The chain was broken – DNSSEC and Certificate ecosystems
- 10.05 (Today)
 - Both the mechanisms work correctly
 - But ...
 - Can the attacker GUESS what the user only knows?
 - Can the attacker ASK for the secret(s)?

WHAT USERS CHOOSE — PASSWORD

HOW DO WE CHOOSE OUR PASSWORD

- A few strategies
 - (12345678) Easy to memorize and type
 - (OregonBeaverRocks) Some phrases familiar
 - (Oregon1234) Add numbers on the phrase
 - (password1234!!) Add special characters at the end
 - ...

HOW STRONG IS THAT PASSWORD



- On what basis
 - Length
 - Composition (the use of special characters)
 - Predictability and vulnerability (a dictionary attack could work?)
 - ...

MEASURING PASSWORD (STRENGTH)

HOW DO WE MEASURE THE PASSWORD STRENGTH

$$H(X) := - \sum_{x \in \mathcal{X}} p(x) \log p(x),$$

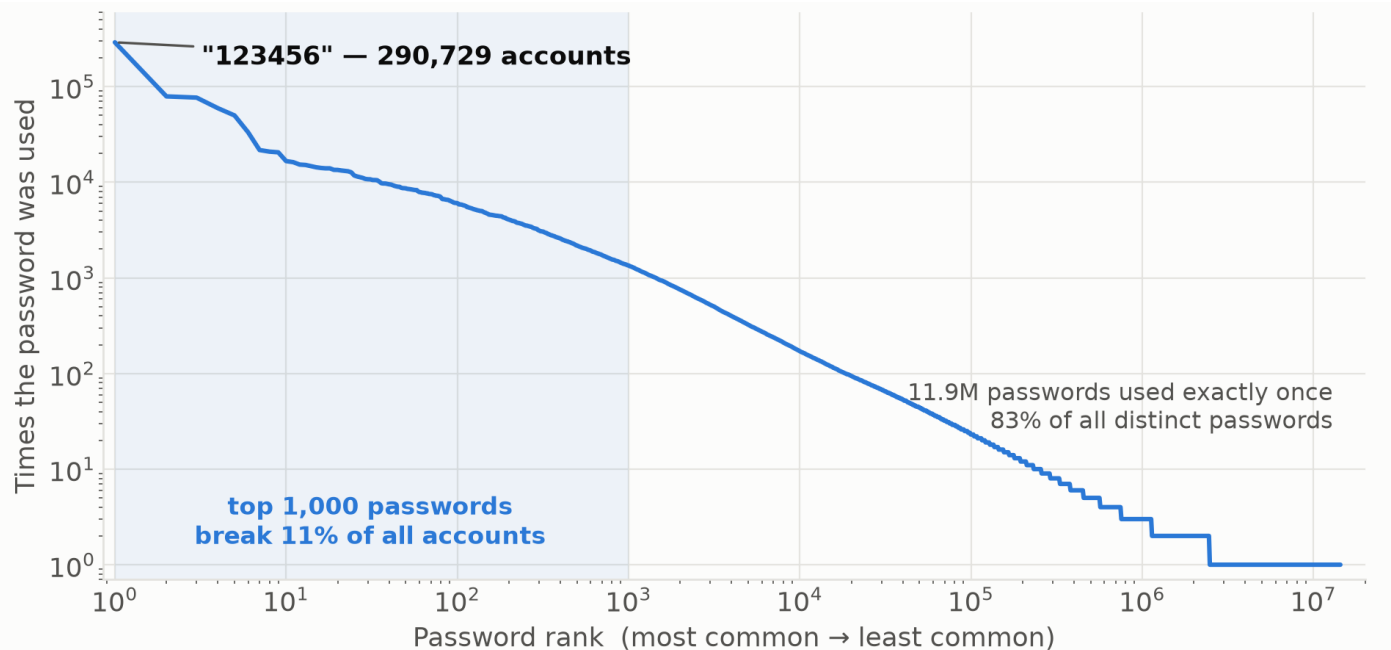
- Shannon's entropy
 - A way to measure the uncertainty in a distribution
 - It measures average surprise over the population – good for
 - Data compression
 - Machine learning (channel capacity, decision-tree splits, ...)
 - [NIST SP 800-63-1](#)
 - [NIST SP 800-63-4](#)
 - ... [more](#)

SHANNON'S ENTROPY – INCORRECT CHOICE FOR SECURITY

- The attacker is different from the entropy model
 - Suppose that the password is
 - 13 characters and consists of [A-Za-z0-9]
 - = 62^{13} possible combinations ($2.002854e^{23}$)
 - The attacker does not try things randomly
 - You live in 'Portland' – so it may start from this word
 - = 62^5 possible combinations ($9.1613283e^8$)
 - = 10^{15} smaller
 - The attacker is greedy
 - Once we break your password "PortlandBeavers!@123"
 - It does not matter the others; the adversary stops there

SHANNON'S ENTROPY – INCORRECT CHOICE FOR SECURITY

- RockYou breach corpus
 - 32.6 M passwords, and 14.3M distinct passwords
 - Zipf-like distribution – a fat head and a long-tail

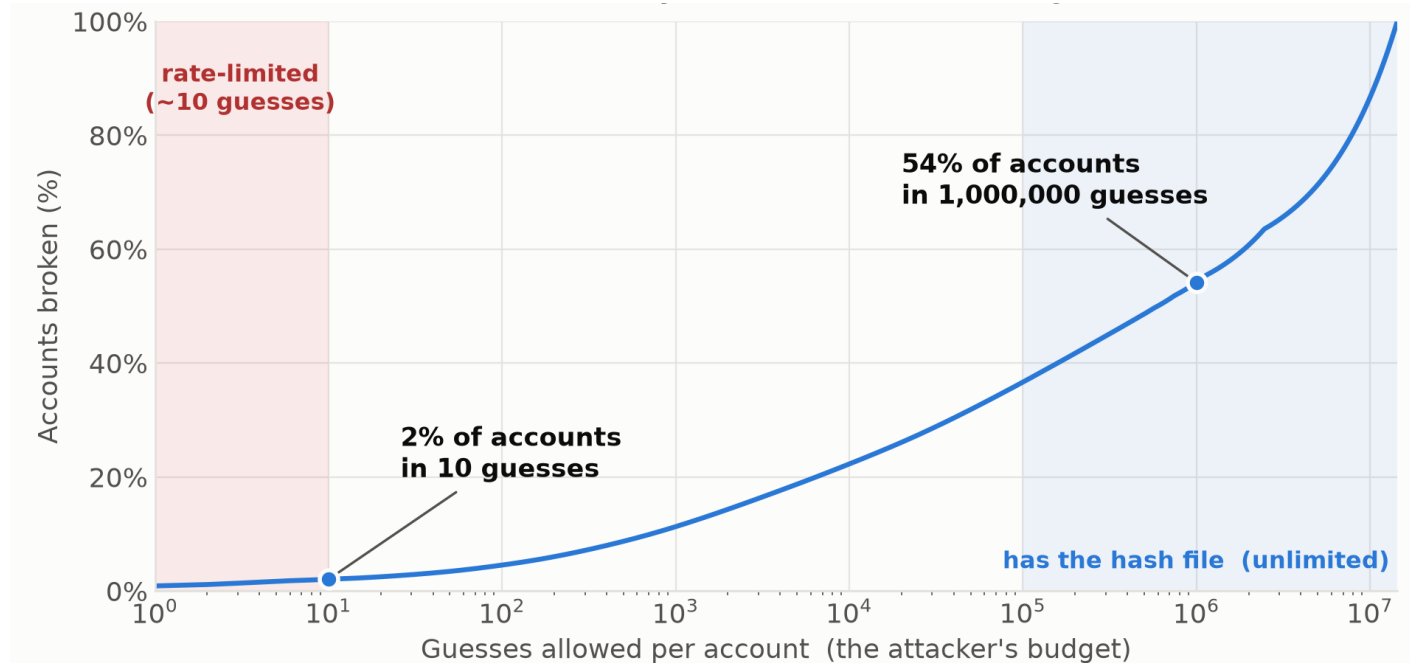


SHANNON'S ENTROPY – INCORRECT CHOICE FOR SECURITY

- RockYou breach corpus
 - 32.6 M passwords, and 14.3M distinct passwords
 - Zipf-like distribution – a fat head and a long-tail
 - Top 1k passwords: 6.5% entropy, 11.3% accounts broken in 1k guesses
 - 11.9M passwords: 43.2% entropy, 36.5% accounts broken in 10^7 guesses

SHANNON'S ENTROPY – INCORRECT CHOICE FOR SECURITY

- RockYou breach corpus
 - 32.6 M passwords, and 14.3M distinct passwords
 - “How secure” depends on the attacker’s budget



HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

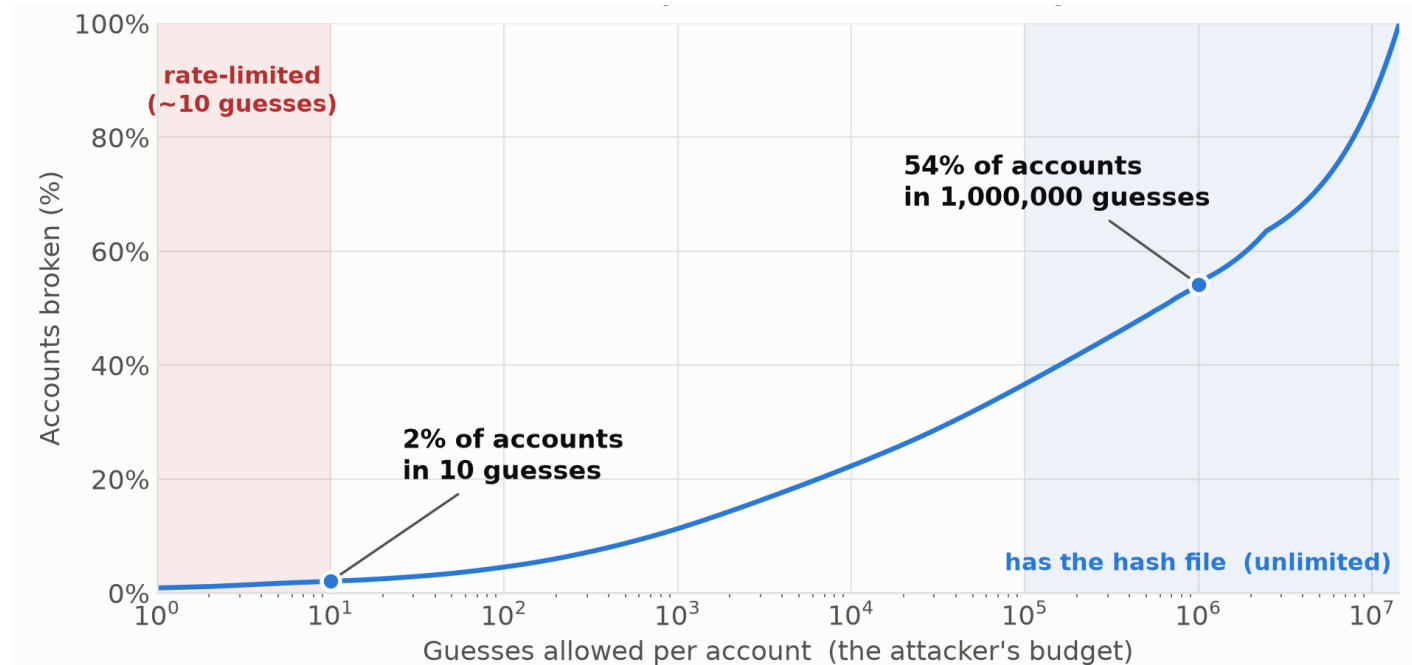
- 70M Yahoo! Users
 - How can we study real-user passwords without seeing them?
 - Hash: $H(\text{"super-secure-password!@\$11"} \parallel \text{a universal nonce})$
 - We only need frequency counts, not the real ones
 - Demographics are used once we have histograms (by age, for example)

HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

- Threat models
 - Online attacker
 - Can access the login form
 - Can perform a network login attempt(s)
 - Can be blocked by a defense technique(s), e.g., rate-limiting
 - Offline attacker
 - Can access the stolen hash file (a dictionary)
 - Can perform hash computations locally
 - Can only be *slower* when complex hashing mechanisms used

HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

- Threat models
 - Online attacker vs. offline attacker



HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

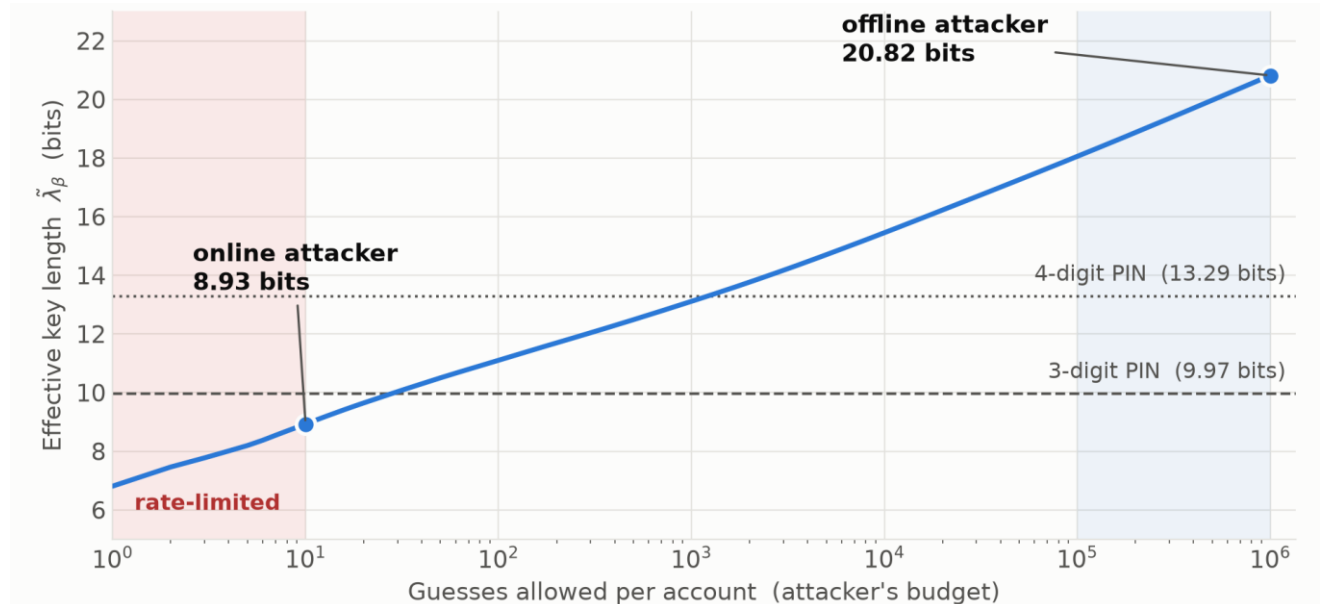
- Proposed metrics to measure *the budget*
 - β -success rate (online attacker)
 - λ_β = sum of the β -most likely password's probabilities
 - Basically, what fraction of accounts fall within β guesses?
 - α -work factor (offline attacker)
 - U_α = the smallest dictionary that breaks a fraction α
 - Basically, how many guesses to break 25% of accounts?
 - α -guesswork
 - G_α = expected guesses per account to reach α
 - A real adversary stops early on each account once broken
 - U_α considers an adversary using the full dictionary every time

HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

- Make it comparable in one unit (let's do it in the RockYou dataset)
 - Observed : 10 guesses broke 2.05% of accounts
 - Uniform over N : 10 guesses break $10/N$
 - # random trials : $10/N = 0.0205$, $N = 488$
 - In bits $\hat{\lambda}_\beta$: $\log_2 488 = 8.93$ bits (β / λ_β)
- Note on $\hat{\lambda}_\beta$
 - Not a metric measuring an entropy; an effective key length
 - Offers a way to estimate (or approximate) the strengths
 - A uniformly random 3-digit PIN number = 1k options = 9.97 bits

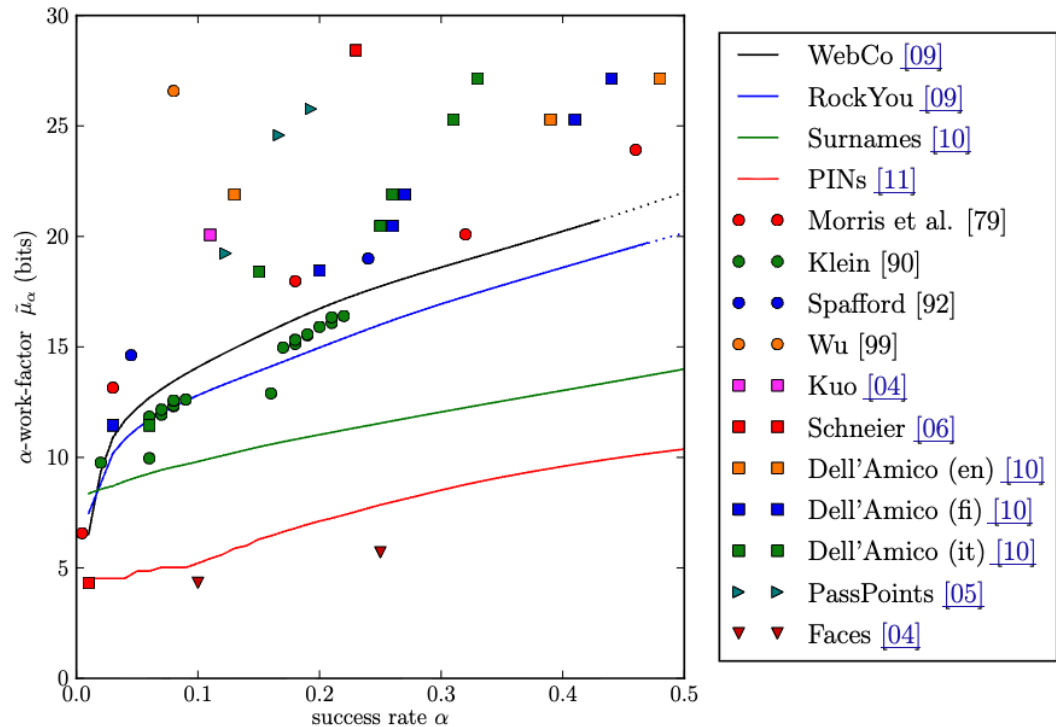
HOW DO WE MEASURE THE PASSWORD STRENGTH IN PRACTICE

- Note on $\hat{\lambda}_\beta$
 - Offers a way to estimate (or approximate) the strengths
 - A uniformly random 3-digit PIN number = 1k options = 9.97 bits
 - Offline attacker needs 20.82 bits = needs to explore 1M options



THE FIRST SURPRISING FINDING

- Passwords have not been changed too much
 - Cracking studies from 1979 to 2010
 - Klein's 1990 study is very close to the optimal attack on the 2011 password datasets



THE FIRST SURPRISING FINDING – CONT'D

- Passwords have not been changed too much
 - Cracking studies from 1979 to 2010
 - Klein's 1990 study is very close to the optimal attack on the 2011 password datasets
- Not just Yahoo

	M	$\hat{H}_\infty$	$\hat{\lambda}_{10}$	$\hat{G}_{0.25}$	$\hat{G}_{0.5}$
Yahoo! (2011)	69301337	6.5	9.1	17.6	21.6
RockYou (2009)	32603388	6.8	8.9	15.9	19.8
Battlefield Heroes (2011)	548774	7.7	9.8	16.5	20.0

Table III
COMPARISON OF YAHOO! DATA WITH LEAKED DATA SETS

- Online metrics (H, λ) differ by only within 1-bit; offline ones (G) differ by < 2 bits
- 1 bit = a factor of 2 in attacker effort
- Across a photo-sharing, a gaming and a web portal, the results are the same

THE SECOND SURPRISING FINDING

- Not much variations between subpopulations (see Table V in the paper)
 - H : 5.0 – 9.1 bits
 - λ : 7.5 – 10.9 bits
 - across 328 sub-populations
- A few notable variations
 - Users who stored a payment card tend to use (2 bits) stronger passwords
 - Youngest users use 1-bit more secure passwords than the oldest
 - Indonesian speakers use the weakest ones, while German and Koreans relatively strong
- A notable lesson from the variations
 - “Let’s educate users” approach may not work as expected
 - In online, where rate-limiting is there, they observe + 2-bit secure passwords
 - In offline, where a breach actually hurts, they observe using less secure ones...

THE SECOND SURPRISING FINDING – CONT'D

- A few notable variations
 - Users who stored a payment card tend to use (2 bits) stronger passwords
 - Youngest users use 1-bit more secure passwords than the oldest
 - Indonesian speakers use the weakest ones, while German and Koreans relatively strong

Target users' language	Chinese	4.4	1.9	2.7	2.4	1.7	2.0	2.0	2.9	1.8	1.7	2.0	2.9
	German	2.0	6.5	2.1	3.3	2.9	2.2	2.8	1.6	2.1	2.6	1.6	3.5
	Greek	9.3	7.7	13.4	8.4	7.4	8.1	8.0	8.0	7.7	7.8	7.7	8.6
	English	4.4	4.6	3.9	8.0	4.3	4.5	4.3	3.4	3.5	4.2	3.5	7.9
	French	2.7	4.0	2.9	4.2	10.0	2.9	3.2	2.2	3.1	3.4	2.1	5.0
	Indonesian	6.7	6.3	6.5	8.7	6.3	14.9	6.2	5.8	6.0	6.2	5.9	9.3
	Italian	4.0	6.0	4.6	6.3	5.3	4.6	14.6	3.3	5.7	6.8	3.2	7.2
	Korean	3.7	2.0	3.0	2.6	1.8	2.3	2.0	5.8	2.4	1.9	2.2	2.8
	Portuguese	3.9	3.9	4.0	4.3	3.8	3.9	4.4	3.5	11.1	5.8	2.9	5.1
	Spanish	3.6	5.0	4.0	5.6	4.6	4.1	6.1	3.1	6.3	12.1	2.9	6.9
	Vietnamese	7.0	5.7	6.2	7.7	5.8	6.3	5.7	6.0	5.8	5.5	14.3	7.8
		Chinese	German	Greek	English	French	Indonesian	Italian	Korean	Portuguese	Spanish	Vietnamese	global

Dictionary used by the attacker

THE THIRD SURPRISING FINDINGS

- “Let’s educate users” approach may not work
 - In online, where rate-limiting is there, they observe + 2-bit secure passwords
 - In offline, where a breach actually hurts, they observe using less secure ones
- Yahoo!’s A/B accident
 - Two sign-up forms: one without any guidance, the other with 6-char, a strength indicator
 - No difference in security against online adversaries
 - < 1-bit increase in security against offline metrics
- Potentially effective approach(es)
 - Rate-limiting and lockout
 - Breach-corpus-based blocklists (credential-stuffing detection)
 - Password managers, 2FA/passkeys

WHAT USERS CLICK — IN-CLASS PRESENTATION BY ORIA

"Sunrise to Sunset: Analyzing the End-to-end Life Cycle and Effectiveness of Phishing Attacks at Scale"

Paper Presentation

CS 578 - Oria Weng

Phishing

- A type of social engineering attack
- Involves impersonation
- "Large-scale attacks": push phish to as many people as possible
- Phishing kits

Existing Work + Limitations

- APWG = Anti-Phishing Working Group
- Lack of consistency across methodologies and data sources
- Heijden and Allodi: click data -> phish effectiveness
- Han et al.: lifecycle analysis on honeypots

What is different about the *Golden Hour*?

- Partnered with a major financial services provider
- Uses real web requests
- Concrete framework that can be used at many different organizations

Contributions

- What does the timeline of an average phishing attack look like?
- How much time is there between attack start and detection?
- How effective is detection at reducing attack effectiveness?

Data Collection

- Impersonating sites often send traffic requesting or redirecting to resources from the organization they are impersonating (especially ones built with kits)
- Web events taken from web traffic logs, tracking, JS code

Golden Hour

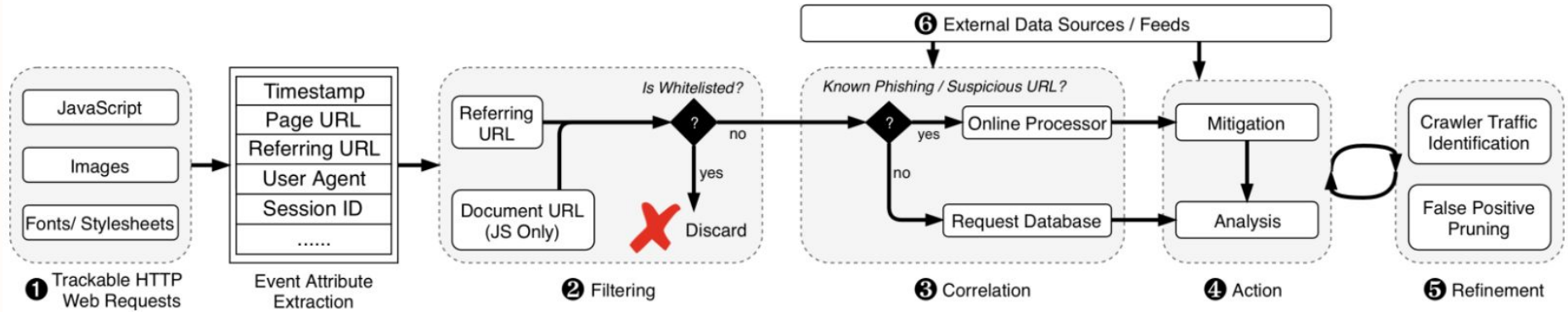


Figure 2: Golden Hour framework design.

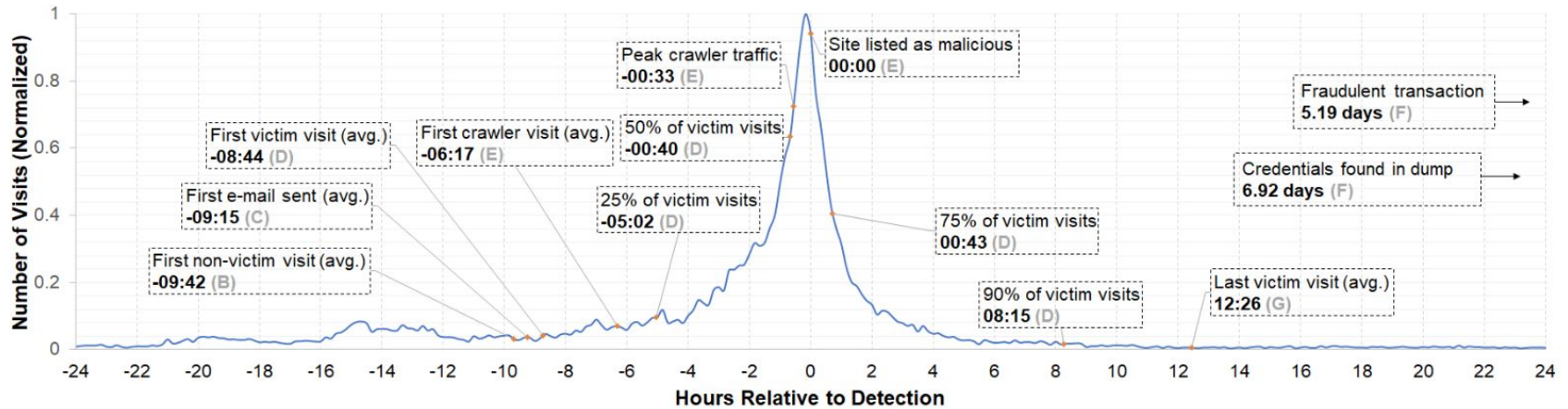
(Image from page 5 of the paper.)

Deployment

- Deployed live from July 1, 2019 to September 30, 2019
- Processed historical data for the 9 months before

19,359,676 events - 3,194,031 benign $\Rightarrow$ 404,628 URLs

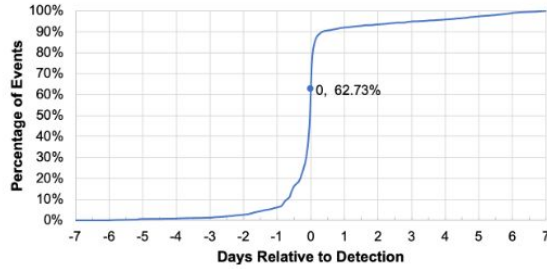
Results



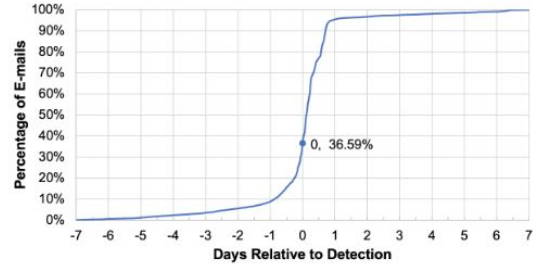
(Image from page 9 of the paper.)

Results

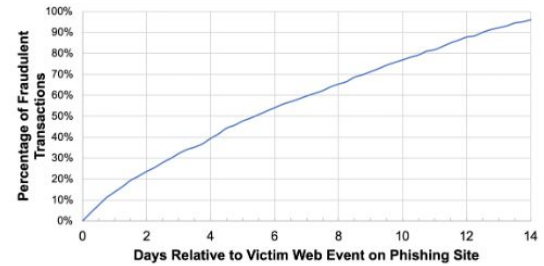
Figure 5: Histogram of Compromised Visitor traffic to phishing websites, annotated with attack stages.



(a) Compromised Visitor traffic.



(b) Phishing email distribution.



(c) Fraudulent transactions over time.

Figure 6: Cumulative Density Function (CDF) plots depicting key phishing attack stages.

Results

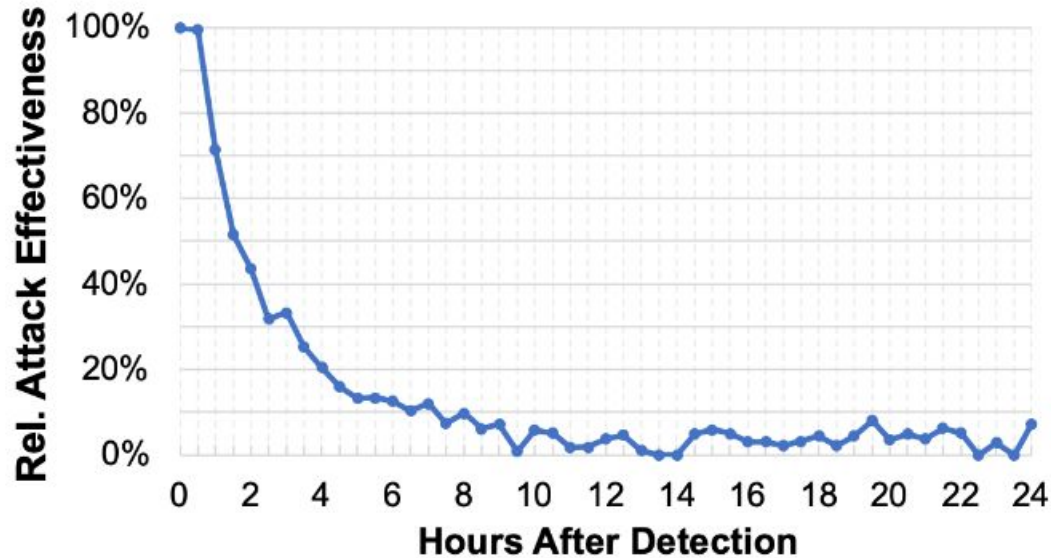


Figure 7: Impact of browser-based detection on phishing effectiveness.

(Image from page 9 of the paper.)

Results

- How often are visits followed by fraudulent transactions?
 - 7.42% of *Known Visitors*
 - 5.19 days of delay
 - 63.61% of credentials go to public dump, after 6.92 days

Results

- Identified elements of most sophisticated phishing sites
 - *Referring URL* event
 - Use of HTTPS

Results

- Visibility:
 - 39.1% of all hostnames
 - 40.9% of all URLs

Applications

- Permanently adopted by the partnered organization for flagging accounts at risk of compromise
- Can be used on live or historical data
- Can be used for any organization

Discussion

- What are the limitations of this study's results?
- How could this study be replicated? What other scenarios could the *Golden Hour* be used on? What factors could affect the outcomes?

Thank You!

Sanghyun Hong

<https://true-lab.ai/courses/Sec-Grad/current>



Oregon State
University



TRUE AI
Trustworthy and Responsible AI